管理系統文件

文件類別	第 二 階 文 件	
文件編號	ISMS-P-09	
文件名稱	資通安全事件通報及應變管理程序書	
發行單位	資通安全處理小組	
發行日期	2024 年 09 月 11 日	
版次	V 1.1	
訂修廢單位	審　　查	核　　准
資通安全處理小組		

（文件訂修廢申請紀錄保存於資通安全處理小組）

管制文件

訂 修 廢 記 錄		
版次	發行日期	訂 修 廢 內 容 摘 要
V1.0	2023/08/08	初版發行
V1.1	2024/09/11	修正 5.5.3 內容誤值

管制文件

1. 目的

1.1. 為使本公司資通安全事件之處理有一明確之規範，將安全及失效事件所造成的損害降到最低，並且建立事件學習機制，以識別重複發生的安全或失效事件。

1.2. 確保本公司於資通安全事件發生時，能迅速依通報程序進行通報，並採取必要之應變措施，降低事件可能帶來之衝擊與損害。

2. 適用範圍

發生於本公司之事件，系統、服務或網路狀態經鑑別而顯示可能有違反資通安全政策或保護措施失效之狀態發生，影響資通系統機能運作，構成資通安全政策之威脅者。

3. 參考文件

3.1. 資通安全管理法。

3.2. 資通安全事件通報及應變辦法。

3.3. ISMS-P-06 業務持續管理程序書。

3.4. ISMS-P-10 矯正及預防管理程序書。

4. 名詞定義

4.1. 威脅情資：有關潛在威脅和攻擊者活動的資訊，這些資訊可用於分析、預測和防止可能對組織或系統造成危害的威脅。威脅情資可以包括來自多個來源的各種資料，例如惡意軟體的樣本、攻擊事件的數據、駭客組織的行為、漏洞的資訊等。

4.2. 資通安全事件：指系統、服務或網路狀態經鑑別而顯示可能有違反資通安全政策或保護措施失效之狀態發生，影響資通系統機能運作，構成資通安全政策之威脅。

4.3. 資通安全事故：指單一或一連串有顯著機率可能危害業務正常運作與威脅資通安全的資通安全事件；同時為本程序所定義 3 級以上之資通安全事件。資通安全事故之處理，依 3 級以上資通安全事件處理流程執行。

4.4. 發現人員：指所有人員含正式員工與非正式員工（臨時員工或委外廠商派駐本公司人員），發現疑似資通安全事件時，皆負有即時通報之責任。

管制文件

4.5. 復原目標時間（Recovery Time Objective, RTO）

資通安全事故發生後，關鍵營運流程中所有相關聯之利害關係者，所期望營運流程中斷復原之時間點。

管制文件

5. 作業內容 Operation content

5.1. 資通安全事件通報及應變管理流程圖
Information security incident reporting and response management flow chart

Operation Process	Responsible Unit	Related forms
Threat Intelligence/ Collection	Found people	Threat Intelligence Analysis Table/ Information security incident report
evaluate (否 / 是)	Information Security Processing Team Unit Manager/Chief Information Security Officer	Information security incident report
Implementation of notification procedures	Information Security Processing Team/ Emergency Response Team	Information security incident report
Implement emergency procedures	Emergency Response Team	
Restoration, Identification, Adjustment Investigation and improvement mechanism	Information Security Processing Team	Information security incident report
Abnormal improvement and handling	Information Security Processing Team Unit Manager/Chief Information Security Officer	Information security incident report
Record keeping	Information Security Processing Team	Information security incident report

管制文件

5.2. 責任

5.2.1. 本公司所屬人員於發現資通安全事件時，應依本程序或權責人員之指示，執行通報及應變事務。

5.2.2. 本公司應視必要性，與受託機關約定，使其制定其「資通安全事件通報及應變管理程序」，並於知悉資通安全事件後向本公司進行通報，於完成事件之通報及應變程序後，依本公司指示提供相關之紀錄或資料。

5.3. 威脅情資蒐集

5.3.1. 取得威脅情資的方法包括主動情資收集和被動情資收集。主動情資收集通常涉及主動監視威脅情報源，例如黑暗網路、開放式情報收集、安全廠商報告等。被動情資收集則是利用組織的安全事件記錄、入侵偵測系統、安全資訊和事件管理（SIEM）等工具，來分析現有的資訊和數據。

5.3.2. 威脅情資監測人員負責監控和檢測威脅情報的來源，確保威脅情報的即時收集和處理監測威脅情報來源，如公開網站、社交媒體、情報共享平台等，對收集到的威脅情報進行分析和評估以確定威脅的嚴重程度和可能的影響並建立「ISMS-P-09-01 威脅情資分析表」，提供給相關人員和管理層共享威脅情報和資料，在必要時將威脅情報共享給外部合作夥伴或第三方機構。

5.3.3. 在發現具體威脅或攻擊事件時，立即通報給管理層和資安處理小組依據本程序規範通報並採取必要的措施以應對和解決威脅事件，並使用適當的安全措施，保護威脅情報資料的完整性和可用性。

5.4. 威脅情資分享效益

5.4.1. 組織可以迅速取得其他組織發現的新型威脅資訊。這有助於迅速識別新的攻擊向量、惡意軟體或攻擊技巧，並更早地開始防禦措施。

5.4.2. 組織能夠更好地了解威脅情勢和攻擊趨勢，有助於加強安全防護措施，將更多的焦點放在潛在的威脅領域上。

5.4.3. 藉由知悉其他組織遇到的攻擊事件和漏洞，組織能夠採取適當的措施，降低可能遭受攻擊的風險。

5.4.4. 促進不同組織之間的合作和合作，彼此之間能夠共同對抗共同的威

脅，形成更強大的安全社群。

5.4.5. 增加組織成員對威脅的認識，提高安全意識，幫助員工識別和應對可能的攻擊，同時組織能夠更快地作出回應，減輕威脅造成的損失和損害。

5.4.6. 有助於監控和追蹤威脅行動，了解攻擊者的行為和手法，幫助制定更有效的對策。

5.5. 發現資通安全事件 Discovery of Information Security Incidents

5.5.1. 若發現或疑似資通安全事件時，由發現人員依事件歸屬迅速通報「資通安全處理小組」，並告知直屬單位主管。
If an information security incident is discovered or suspected, the person who discovers it shall promptly report it to the "Information Security Handling Team" and inform their immediate supervisor.

5.5.2. 「資通安全處理小組」於收到通知後，研判是否為資通安全事件。
Upon receiving the notification, the "Information Security Handling Team" shall assess whether it qualifies as an information security incident.

5.5.2.1. 若判定為非資通安全事件時，將結果回覆發現人，並協助處理及解決問題。
If it is determined not to be an information security incident, the findings shall be communicated to the discoverer, and assistance will be provided to address and resolve the issue.

5.5.2.2. 若判定為資通安全事件時，則應依本程序之規定，儘速完成損害控制、復原與事件之調查及處理作業。
If it is determined to be an information security incident, damage control, recovery, investigation, and handling operations shall be promptly completed in accordance with this procedure.

5.5.2.3. 事件通報窗口及緊急處理小組
Incident Reporting Point and Emergency Response Team

5.5.2.3.1. 本公司應以適當方式使相關人員明確知悉本公司之通報窗口及聯絡方式。
The company shall ensure that relevant personnel are clearly informed of the reporting point and contact information through appropriate means.

5.5.2.3.2. 本公司所屬人員發現資通安全事件後，應立即向所屬單位主管及本公司之通報窗口通報。
Upon discovering an information security incident, employees must

管制文件

immediately report it to their supervisor and the company's reporting point.

5.5.2.3.3. 本公司應確保通報窗口之聯絡管道全天維持暢通，若因設備故障或其他情形導致窗口聯絡管道中斷，該中斷情況若持續達一小時以上者，應即將該情況告知相關人員，並即提供其他有效之臨時聯絡管道。

The company shall ensure that the contact channels for the reporting point remain open 24/7. If communication is interrupted due to equipment failure or other circumstances and lasts for more than an hour, the situation shall be communicated to relevant personnel, and alternative temporary contact methods must be provided immediately.

5.5.2.3.4. 負責事件處理之單位（該事件發生之單位）權責人員，應與相關單位密切合作以進行事件之處理，並使通報窗口適時掌握事件處理之進度及其他相關資訊。

The responsible personnel of the unit where the incident occurred must work closely with related departments to handle the incident and ensure that the reporting point is kept informed of progress and other relevant information.

5.5.2.3.5. 事件經初步判斷認為可能屬重大資安事件或事態嚴重時，應即向「資通安全長」報告，由「資通安全長」成立「緊急處理小組」，立即協助進行處理；接獲本公司受託廠商所通報之資通安全事件時，亦同。

If a preliminary assessment suggests that the incident might constitute a major information security event or is of a severe nature, it must be reported immediately to the "Chief Information Security Officer" (CISO). The CISO shall form an "Emergency Response Team" to assist in handling the incident promptly. The same applies when information security incidents reported by contractors are received.

5.5.3. 「資通安全處理小組」於發生資通安全事件時，應將事件發生之事實、可能影響之範圍、損失評估、判斷支援申請、採取之應變措施等事項，詳細記錄於「ISMS-P-09-02 資通安全事件通報單」中。

The "Information Security Handling Team" must record the details of the incident, including the facts of the occurrence, the possible scope of impact, loss assessment, judgment of support requests, and response measures, in the "ISMS-P-09-02 Information Security Incident Report Form."

5.6. 執行通報程序 Execution of the Reporting Procedure

5.6.1. 資通安全事件發生時，應先研判本公司資通安全事件分類與「資通安全事件通報及應變辦法」資通安全事件等級之對應。

When an information security incident occurs, it must first be assessed according to

the company's classification of information security incidents and the corresponding levels in the "Information Security Incident Reporting and Response Guidelines."

5.6.2. 資通安全事件等級共分為 4 級，如下說明。

Information security incidents are classified into four levels, as described below.

評估類別 影響等級	機密性	完整性	可用性
1 級	非核心業務資料遭輕微洩漏	非核心業務資訊或非核心資通系統遭輕微竄改	非核心業務運作受影響或停頓，於可容忍中斷時間內回復正常運作，造成公司日常作業影響
2 級	非核心業務資訊遭嚴重洩漏，或未涉及關鍵設施維運之核心業務資訊遭輕微洩漏	非核心業務資訊或非核心資通系統遭嚴重竄改，或未涉及關鍵設施維運之核心業務資訊或核心資通系統遭輕微竄改	非核心業務之運作受影響或停頓，無法於可容忍中斷時間內回復正常運作，或未涉及關鍵設施維運之核心業務或核心資通系統之運作影響或停頓，於可容忍中斷時間內回復正常運作
3 級	未涉及關鍵設施維運之核心業務資訊遭嚴重洩漏，或一般機敏資訊或涉及關鍵設施維運之核心業務資訊遭輕微洩漏	未涉及關鍵設施維運之核心業務資訊或核心資通系統遭嚴重竄改，或一般機敏資訊、涉及關鍵設施維運之核心業務資訊或核心資通系統遭輕微竄改。	未涉及關鍵設施維運之核心業務或核心資通系統之運作受影響或停頓，無法於可容忍中斷時間內回復正常運作，或涉及關鍵設施維運之核心業務或核心資通系統之運作受影響或停頓，於可容忍中斷時間內回復正常運作
4 級	一般機敏資訊或涉及關鍵設施維運之核心業務資訊遭嚴重洩漏，或國家機密遭洩漏	一般機敏資訊、涉及關鍵設施維運之核心業務資訊或核心資通系統遭嚴重竄改，或國家機密遭竄改	涉及關鍵設施維運之核心業務或核心資通系統之運作受影響或停頓，無法於可容忍中斷時間內回復正常運作

5.6.3. 資通安全事件若危及人民生命或涉及民、刑事案件時，本公司各單位應即時通報檢調單位協助處理。

If an information security incident endangers lives or involves civil or criminal cases, the company's units must immediately report to the relevant investigation and law enforcement agencies for assistance.

5.6.4. 與外單位交流 Collaboration with External Units

各單位間應加強合作協調，實施項目如下：

Each unit should enhance cooperation and coordination to implement the following measures:

5.6.4.1. 應與外部的資訊專家或顧問加強協調聯繫，相互合作，以評估單位面臨資安威脅之處理措施。
Strengthen coordination and communication with external information experts or consultants to assess and address potential information security threats.

5.6.4.2. 與業務上有密切關係之機關，建立及維持適當互動管道，以利發生資安危機時，可獲得外部支援解決問題。
Establish and maintain proper interaction channels with agencies closely related to the company's business to obtain external support for problem resolution during an information security crisis.

5.6.4.3. 對各項資訊業務委外廠商，應於契約規範建立資通安全及防衛網路攻擊之環境。
Contracts with outsourced vendors for information services must include provisions for creating a secure environment to prevent network attacks.

5.6.4.4. 記錄本公司資通安全事項之文件或資訊，於提供外界使用及經驗交流時，應予適當限制，以防敏感性資訊遭未經授權者任意取得。
Proper restrictions must be placed on the sharing of the company's information security documentation or information with external parties to prevent unauthorized access to sensitive data.

5.6.5. 資通安全事件通報程序 Information Security Incident Reporting Procedure
當本公司發生資通安全事件時，應採取以下的通報程序處理。
In the event of an information security incident, the company should follow the reporting procedure outlined below:

5.6.5.1. 「資通安全處理小組」應視事件類型採取應變程序因應，必要時得進行系統切換作業，並完成通報作業。
The "Information Security Handling Team" shall adopt appropriate response measures depending on the type of incident. If necessary, system switching operations should be performed, and the reporting process completed.

5.6.5.2. 相關權責主管接獲通報後，視事件發生原因與處理狀況成立「緊急處理小組」進行異常事件排除，並將目前處理狀況持續向相關權責主管報告。
Relevant supervisors shall establish an "Emergency Response Team" to resolve abnormal incidents and continuously report the current handling status to relevant authorities.

5.6.5.3. 「緊急處理小組」由「資通安全長」指派組織之資通安全相關技術人員擔任，或亦得由其他機關資通安全相關技術人員或外部

專家擔任之。
The "Emergency Response Team" shall consist of information security personnel assigned by the Chief Information Security Officer (CISO) or other qualified technical staff, including external experts.

5.6.5.4. 判定事件等級之流程及權責 Determining the Level of Incidents

本公司之權責人員或「緊急處理小組」應依據以下事項，於知悉資通安全事件後，依本程序規定完成資通安全事件等級判斷：
Relevant personnel or the "Emergency Response Team" shall determine the level of the information security incident based on the following factors:

5.6.5.4.1. 事件涉及核心業務或關鍵設施業務之資訊與否。
Whether the incident involves core business or critical infrastructure operations.

5.6.5.4.2. 事件導致業務之資訊或資通系統遭竄改之影響程度，屬嚴重或輕微。
The severity of the impact caused by tampering with business information or information systems.

5.6.5.4.3. 事件所涉資訊是否屬於國家機密、敏感資訊或一般公務機密。
Whether the information involved is classified as national secrets, sensitive information, or general administrative secrets.

5.6.5.4.4. 公司業務運作若遭影響或資通系統停頓，是否可容忍中斷時間內能回復正常運作。
The company's ability to resume normal operations within a tolerable interruption time.

5.6.5.4.5. 事件其他足以影響資通安全事件等級之因素。
Any other factors that could affect the classification of the information security incident.

5.6.5.5. 除事件之等級外，權責人員或「緊急處理小組」亦應對資通安全事件之影響範圍、損害程度及本公司因應之能力進行評估。
In addition to determining the incident's level, the relevant personnel or "Emergency Response Team" must evaluate its scope, damage severity, and the company’s capacity to respond.

5.6.5.6. 本公司權責人員或「緊急處理小組」於完成資通安全事件等級之判斷及相關評估後，應盡速報「資通安全長」核准。
Once the level and evaluation of the information security incident are completed, the findings must be promptly submitted to the CISO for approval.

5.6.5.7. 資通安全事件等級如有變更，權責人員或緊急應變小組應告知通報窗口，使其續行通報作業。
If the level of the information security incident changes, the relevant personnel or Emergency Response Team must inform the reporting point to continue the notification process.

5.6.5.8. 本公司於委外辦理資通系統之建置、維運或提供資通服務之情形時，應於合約中訂定委外廠商於知悉資通安全事件時，應即向本公司之權責人員或窗口，以指定之方式進行通報。
Contracts with outsourced vendors must include clauses requiring vendors to report information security incidents to the company's designated personnel or contact point.

5.7. 執行應變程序 Execution of Response Procedures

5.7.1. 當事件影響較低、衝擊性較小，僅涉及單位內部且受損程度輕微時（如內部小範圍電腦病毒感染），由發生事件之業務單位派員處理。
If the incident has low impact and affects only internal operations (e.g., localized virus infections), it shall be handled by personnel from the affected business unit.

5.7.2. 處理過程中如發現造成之影響大於原先判定事件，應重新執行事件分析辨識，並依資通安全事件通報規定重新進行通報。
If the impact exceeds the initial assessment, the incident must be re-analyzed, and the reporting process restarted.

5.7.3. 處理資通安全事件時，若需其他資源，則由資通安全長負責溝通協調作業，並適時提供「資通安全處理小組」必要的協助。
If additional resources are required, the CISO shall coordinate the efforts and provide necessary assistance.

5.7.4. 有關是否啟動業務持續計畫，依「ISMS-P-06 業務持續管理程序書」之規定辦理。
Whether to activate the Business Continuity Plan shall be determined according to the "ISMS-P-06 Business Continuity Management Procedure Manual."

5.7.5. 當資通安全事件發生需對外說明時，主管須向資通安全長詳細報告事件情況與處置方式，並由資通安全長對外說明，視情況向上級主管機關陳報。
If external communication is required, the CISO must report the details and handling measures to supervisors and communicate externally.

5.7.6. 如遇資通安全事件危及人員生命或設備遭到破壞時，情況緊急需當下處理時，由資通安全長及時協調相關單位共同處理。
In emergencies involving threats to lives or severe equipment damage, the CISO shall

coordinate with relevant units for immediate action.

5.7.7. 應變處理程序 Crisis Management Process

本公司資通安全危機處理包括事前建置安全防護機制、事中主動預警緊急應變及事後復原追蹤鑑識偵查等步驟。說明如下：

The company's information security crisis management includes the following steps: pre-establishing security protection mechanisms, active warning and emergency response during incidents, and post-incident recovery, tracking, forensic investigation, and analysis. The details are as follows:

5.7.7.1. 事前建置安全防護機制 Pre-event Security Mechanism Establishment

5.7.7.1.1. 本公司應以組織營運目標與策略為基準，透過整體之營運衝擊分析，規劃業務持續運作計畫並實施演練，以預防資安事件之發生。

Develop a business continuity plan and conduct drills based on organizational goals to prevent information security incidents.

5.7.7.1.2. 建置資通安全系統及整體防護架構，增加防禦能力，以減少事件發生。事前完備的防護機制，可增進處理事件之應變速度及減少損害程度。

Build comprehensive information security systems to enhance defense capabilities.

5.7.7.1.3. 彙整資安文件：資通安全相關文件應齊備，以利資通安全事件發生時可參考使用。

Consolidate information security documents for reference during incidents.

5.7.7.2. 事中主動預警、緊急應變 Active Warning and Emergency Response

5.7.7.2.1. 事件辨識：其目的為辨識資通安全事件之歸屬及採取之對策為何？屬內部危安事件、外力入侵事件、天然災害或突發事件，並決定問題處理的方法與程序。

Incident Identification: Determine the nature of the information security incident and appropriate countermeasures.

5.7.7.2.2. 事件控制：依據各類資通安全事件危機處理之程序，進行資通安全事件傷害控制，降低影響的程度及範圍。

Incident Control: Implement damage control procedures to minimize the impact.

管制文件

5.7.7.2.3. 問題解決：資通安全事件處理權責單位或負責人須將問題徹底解決，使系統恢復至資通安全事件發生前的正常運作狀態。Problem Resolution: Resolve issues to restore normal system operations.

5.7.7.3. 損害控制機制 Damage Control Mechanism

5.7.7.3.1. 負責應變之權責人員或「緊急處理小組」，應完成以下應變事務之辦理，並留存應變之紀錄：
The responsible personnel or the "Emergency Response Team" shall complete the following response tasks and maintain records of the response:

A. 資安事件之衝擊及損害控制作業。
Conduct impact assessment and damage control operations for the information security incident.

B. 資安事件所造成損害之復原作業。
Carry out recovery operations for damages caused by the information security incident.

C. 資安事件相關鑑識及其他調查作業。
Perform forensic investigations and other related investigations regarding the information security incident.

D. 資安事件之調查與處理及改善報告之方式。
Compile investigation, handling, and improvement reports related to the information security incident.

E. 資安事件後續發展及與其他事件關聯性之監控。
Monitor the subsequent development of the incident and its association with other incidents.

F. 資訊系統、網路等安全區域發生重大事故或災難，致使業務中斷時，應依據本公司事前擬定之緊急計畫，進行應變措施以恢復業務持續運作之狀態。
If significant accidents or disasters occur in secure areas such as information systems or networks that cause business disruptions, emergency measures shall be implemented based on the company’s pre-established contingency plan to restore business continuity.

G. 其他資通安全事件應變之相關事項。
Address other related matters regarding information security incident response.

5.7.7.3.2. 對於第一級、第二級資通安全事件，本公司應於知悉事件後七十二小時內完成「5.7.7.3.1」事務之辦理，並應留存紀錄；

機密文件

於第三級、第四級資通安全事件，本公司應於知悉事件後三十六小時內完成損害控制或復原作業，並執行上述事項，及留存相關紀錄。

For Level 1 and Level 2 information security incidents, the company shall complete the tasks specified in "5.7.7.3.1" within 72 hours of becoming aware of the incident and maintain corresponding records. For Level 3 and Level 4 incidents, the company shall complete damage control or recovery operations within 36 hours and perform the aforementioned tasks while maintaining relevant records.

5.7.7.3.3. 本公司於知悉受託廠商發生與受託業務相關之資通安全事件時，應於知悉委外廠商發生第一、二級資通安全事件後七十二小時內，確認委外廠商已完成損害控制或復原事項之辦理；於知悉委外廠商發生第三、四級資通安全事件後三十六小時內，確認委外廠商完成損害控制或復原事項之辦理。

Upon becoming aware of information security incidents related to entrusted business activities handled by outsourced vendors, the company shall confirm that the vendor has completed damage control or recovery operations for Level 1 and Level 2 incidents within 72 hours. For Level 3 and Level 4 incidents, the vendor’s completion of damage control or recovery operations must be verified within 36 hours.

5.7.8. 資安事件後之復原、鑑識、調查及改善機制

Post-incident Recovery, Investigation, and Improvement Mechanism

5.7.8.1. 本公司完成資通安全事件之通報及應變程序後，應針對事件所造成之衝擊、損害及影響進行調查及改善，並應於事件發生後一個月內完成資通安全事件調查、處理及改善報告。

After completing the reporting and response procedures for an information security incident, the company shall investigate the impact, damage, and effects of the incident and implement improvements. An information security incident investigation, handling, and improvement report shall be completed within one month of the incident's occurrence.

5.7.8.2. 資通安全事件調查、處理及改善報告應包括以下項目：

The information security incident investigation, handling, and improvement report shall include the following items:

5.7.8.2.1. 事件發生、完成損害控制或復原作業之時間。

The timeline of the incident, including the completion of damage control or recovery operations.

5.7.8.2.2. 事件影響之範圍及損害評估。

The scope of the incident's impact and damage assessment.

5.7.8.2.3. 損害控制及復原作業之歷程。
The process of damage control and recovery operations.

5.7.8.2.4. 事件調查及處理作業之歷程。
The process of incident investigation and handling operations.

5.7.8.2.5. 為防範類似事件再次發生所採取之管理、技術、人力或資源等層面之措施。
Measures taken to prevent similar incidents from recurring, addressing management, technical, manpower, or resource aspects.

5.7.8.2.6. 前款措施之預定完成時程及成效追蹤機制。
The planned completion timeline for the aforementioned measures and a mechanism for tracking their effectiveness.

5.7.8.3. 後續追蹤的精神在於檢討原事件是否會重複發生，並審視現有環境的漏洞，藉研析相關資料以釐清事件發生的原因與責任。
The essence of follow-up tracking lies in reviewing whether the original incident is likely to recur and examining existing environmental vulnerabilities. Analyzing relevant data helps clarify the causes and responsibilities associated with the incident.

5.7.8.4. 資通安全事件應保留事件發生之線索，如有需要得向國家資通安全會報技術服務中心或檢警單位申請數位鑑識（電腦、網路鑑識、行動裝置鑑識）。
Clues related to the occurrence of the information security incident must be preserved. If necessary, digital forensics (e.g., computer, network, or mobile device forensics) can be requested from the National Information Security Reporting and Technical Service Center or law enforcement agencies.

5.7.8.5. 為有效追蹤，檢討事件原因，應審視現有環境的漏洞，細節記錄於「ISMS-P-09-02 資通安全事件通報單」。
To effectively track and review the root causes of the incident, existing environmental vulnerabilities should be examined, with details recorded in the "ISMS-P-09-02 Information Security Incident Report Form."

5.8. 異常改善及後續處理 Abnormal Improvement and Follow-Up Handling

5.8.1. 本公司應將資通安全事件之通報與應變作業之執行、事件影響範圍與損害程度以及其他通報應變之執行情形，於「ISMS-P-09-02 資通安全事件通報單」上留存完整之紀錄，該文件並應經承辦之權責人員、「資通安全長」簽核。

管制文件

The company shall maintain complete records of the execution of information security incident reporting and response operations, the scope of the incident's impact, the extent of damage, and other response execution details in the "ISMS-P-09-02 Information Security Incident Report Form." This document must be signed by the responsible personnel and the Chief Information Security Officer (CISO).

5.8.2. 本公司於完成資通安全事件之通報及應變程序後，應依據「ISMS-P-09-02 資通安全事件通報單」之內容及實際處理之情形，於必要時對本管理程序、人力配置或其他相關事項進行修正或調整。

After completing the reporting and response procedures for an information security incident, the company shall revise or adjust this management procedure, personnel allocation, or other related matters as necessary, based on the content of the "ISMS-P-09-02 Information Security Incident Report Form" and the actual handling situation.

5.8.3. 若為重大資通安全事件，於處理完畢且獲得妥善控制後，為落實預防管理及確保資通安全事件不再重複發生，必須由資通安全長或由主管指派專人召集相關單位召開資通安全事件檢討會議，研析問題發生之原因。

For major information security incidents, after the incident has been properly handled and controlled, the CISO or a supervisor-designated specialist must convene a review meeting with relevant units to analyze the causes of the issue, ensuring preventive measures are implemented and such incidents do not recur.

5.8.4. 依據資通安全事件檢討會議之結果，由系統負責人依據「ISMS-P-10 矯正及預防管理程序書」之相關規定執行矯正措施，進行問題矯正的作業，以降低事件再發生的可能性。

Based on the results of the information security incident review meeting, the system manager shall implement corrective measures according to the relevant provisions of the "ISMS-P-10 Corrective and Preventive Management Procedure Manual" to reduce the likelihood of similar incidents.

5.8.5. 資通安全事件完成矯正及預防措施後，需由業務承辦人員針對發生事件之根因進行風險再評估作業，確認此風險已排除並受到適當之控制。

After completing the corrective and preventive measures for an information security incident, the business personnel responsible must conduct a re-assessment of the risks related to the incident's root cause to confirm that the risk has been eliminated and is under proper control.

5.9. 紀錄保存

相關業務承辦人員應參照如下規範，妥善保存各項紀錄。

編號	表單名稱	保存期限
1	威脅情資分析表	至少 3 年
2	資通安全事件通報單	至少 3 年

6. 附件

6.1. ISMS-P-09-01 威脅情資分析表。

6.2. ISMS-P-09-02 資通安全事件通報單。

管制文件